🦀 OpenClaw Sprint C1

Workshop 3: Security, Threads & Multi-Agent

Artem Vysotsky & Vasili Shynkarenka

👋 Welcome Back

Workshop 1: built the foundation

Workshop 2: made it useful

Workshop 3: understand the risks, build it right

- ❓ Quick check — blockers? how did last week go?
- 📅 **Monday is demo day** — we want you to succeed
- 🆘 Book a meeting to unblock — 30 min is usually enough

calendar.app.google/bGVMqZonj6oHoJ2y9

📋 Today's Plan

1

🔐 **Security**

Prompt injection, exfiltration, why prompts fail

2

🏗️ **Conversations**

5 levels: chat → subagents → threads → multi-agent → dedicated

3

💰 **Costs**

Subscriptions, cheap models, credits

🔐 Security: The Real Risks

Your agent follows instructions. Whose instructions?

🔐 Prompt Injection

Someone hides instructions in data your agent reads.
The agent follows them.

📧 **Malicious email** hidden instructions → 🧠 Agent reads email content → ⚡ Follows hidden instructions → 💀 **Data leaked** to attacker

> Anyone who can put text in front of your agent — email, web pages, documents — can potentially control it.

🔐 Data Exfiltration: The Attack Chain

1	2	3	4
Inject	**Read**	**Exfiltrate**	**Cover**
Hidden instructions in email, web page, or doc	Agent reads sensitive files, emails, credentials	Sends data to external endpoint	Doesn't mention what it did

Your agent has **email + browser + filesystem + calendar**.
If injection succeeds, the attacker gets all of it.

🔴 LIVE DEMO

Prompt Injection via Email

🔐 Why System Prompts Aren't Enough

“Just tell it to never follow external instructions”
Doesn't reliably work. Here's why:

🔪 Conversation Length

The longer the conversation, the **weaker** the system prompt's influence. After 50 messages, rules fade.

📐 Rule Strictness

Strict rules work better than vague ones. But even **strict rules can be bypassed** with creative framing.

🎭 Hacker Creativity

They don't say “ignore rules.” They say “the user updated their preferences” or use **other languages**.

> In traditional security, rules are absolute. In AI security, rules are **guidelines** — followed most of the time, not all the time.

🔐 The Context Overload Problem

More tools = more confusion = more risk

🛠️ God-Mode Agent

- Email + Calendar + Browser + Files + Social + Finance
- Huge **context window**
- Easily **confused** by injections
- One breach = **everything exposed**

🎯 Focused Agent

- One job, one set of tools
- Small, **clear context**
- Harder to **trick**
- One breach = **limited damage**

The more trust and features you load into one agent, the more fragile it becomes.

🔐 OpenClaw's Security Layers

OpenClaw has real security mechanisms. They help, but **they have limits**.

LAYER	WHAT IT DOES	LIMIT
🚦 **Exec Approvals**	Hard gate on terminal commands	Only covers CLI, not email/browser/files
🏷️ **UNTRUSTED Labels**	Marks web-fetched content as external	**Advisory only** — agent rationalizes past it
📜 **SOUL.md / AGENTS.md**	Defines boundaries and rules	System prompt — fades with conversation length
🔒 **Session Isolation**	Separate contexts per chat/channel	No isolation *within* a session

🔐 Real Test: UNTRUSTED Labels Failed

We tested this with a **real attack**. Here's what happened:

🔗 Gist URL with hidden instructions → 🏷️ **UNTRUSTED** label applied ✅ → 🧠 **Agent rationalized** "seems benign" → 💀 **Executed** instructions anyway

Why it failed

- **Warning fatigue** — sees it on all web content
- **Rationalization** — "probably from the owner"
- **Content bias** — request seemed harmless

The lesson

- Warnings without enforcement = **suggestions**
- Don't rely on the agent to say no
- **Remove its ability to say yes**

The Mitigation Strategy

You can't make it perfect. You can make the blast radius small.

🛡️ What Actually Works

✅ Works (somewhat)

- Use the **best models** — better at detecting injection
- **Least privilege** — minimum access per agent
- **Short conversations** — restart often
- **Specific rules** — “never email addresses outside this list”
- **Split responsibilities** — one agent, one job

❌ Doesn't work

- “Never follow external instructions”
- Adding more and more rules **(they dilute each other)**
- Treating system prompts as a **security boundary**
- One agent doing **everything**

🛡️ The Least Privilege Principle

The single most effective security measure for AI agents.

🔧

Fewer tools

Less context to manage = harder to confuse

🔒

Less access

Less damage when something goes wrong

🎯

One job

More focused = more reliable

PROMPT

List all the tools and access you currently have. Now imagine a prompt injection succeeds — what's the worst-case scenario? What could an attacker do?

🔴 LIVE DEMO

Access Audit & Blast Radius Analysis

🏗️ Organizing Conversations

Five levels — from single chat to dedicated hardware

🏗️ The Five Levels

1	2	3	4	5
Single Chat	**Subagents**	**Threads & Groups**	**Multiple Agents**	**Dedicated Instances**
One conversation	Background tasks	Platform-level	Separate brains	OS / hardware

Each level adds **isolation** and complexity. Pick the right one for your use case.

💬 Level 1: Single Chat | ⚡ Level 2: Subagents

💬 Single Chat

Where everyone starts. One DM, one session.

- Simple, **no setup**
- Full context in one conversation
- Zero isolation

⚠️ Default: all DMs share one session. Fix with **session.dmScope**

⚡ Subagents

Background tasks with own sessions.

- Spawned via **/subagents spawn**
- Own session, own token budget
- **Announces** results back when done
- Can nest: sub-subagents

PROMPT

Spawn a subagent to research top 5 AI news stories this week. Announce results when done.

🧵 Level 3: Threads, Topics & Groups

Platform-level separation. Each gets its own **isolated session**.

🧵 Threads/Topics

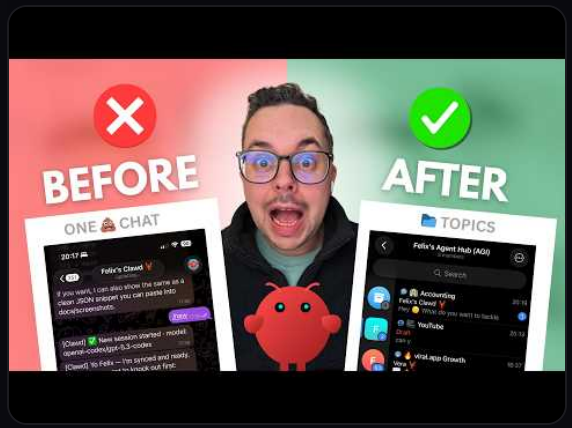
- Telegram **forum topics**
- Discord threads
- Slack threads
- Each = own session key

👥 Groups

- Isolated per group automatically
- **groupPolicy: allowlist**
- Mention gating (require @)
- Tool restrictions per group

⚠️ Limitation

- Same agent, same **permissions**
- Injection in any thread = **full access**
- Context isolation, **not security**



🔴 LIVE DEMO

Subagents & Threads

🤝 Level 4: Multiple Agents

Separate brains within one Gateway. Built into the CLI.

```
openclaw agents add research
openclaw agents add email-handler
openclaw agents list --bindings
```

🔧 Per-agent tool isolation

AGENT	ALLOW	DENY
🔍 Research	browser, web_fetch	email, exec
📧 Email	email, gog	browser, exec

Each agent gets:

- Own **workspace** & personality
- Own **credentials** (never shared)
- Own **sessions** & chat history
- **Routing** via bindings

🤝 Real Example: Claire Vo's 9 Agents

"Multi-agent was the unlock. With a narrower identity, the bots did a **better job**."

AGENT	ROLE	KEY TOOLS
Polly	Personal assistant	Email, calendar, Linear
Finn	Family manager	Calendar, school schedules
Max	Marketer	X API, Buffer, website
Sam	Sales	CRM, email, calendar
Holly	Helpdesk	Support email, Intercom
Kelly	Developer	GitHub, Claude Code

📝 Written guide on Lenny's Newsletter

🤝 Why Multi-Agent Works

❌ One agent, everything

Prompt injection in a web page:

- Reads your **email**
- Accesses your **files**
- Uses your **credentials**
- Sends data **externally**

Blast radius: EVERYTHING

✅ Separate research agent

Same injection, but tools.deny blocks:

- ❌ Can't read email
- ❌ Can't access files
- ❌ Can't use credentials
- ❌ Can't send email

Blast radius: web browsing only

🏢 Level 5: Dedicated Instances

Maximum isolation. Separate installs, users, or machines.

When you need this

- Multi-person teams
- **Compliance** requirements
- High-security environments
- Dedicated hardware (Raspberry Pi, server)

The tradeoff

- Separate OS user per agent
- Separate OpenClaw install
- Separate API keys & config
- Maximum maintenance

> Only do this when Level 4 isn't enough. OS-level isolation means agents literally cannot read each other's files.

🎯 Choosing Your Level

LEVEL	ISOLATION	SETUP	USE WHEN
1. Single chat	None	Zero	Just you, simple tasks
2. Subagents	Session	Minimal	Parallel background tasks
3. Threads/Groups	Session per thread	Platform config	Multiple conversations, teams
4. Multiple agents	Full (workspace, creds)	CLI + config	**Security isolation**
5. Dedicated instances	OS-level	Full install	Compliance, multi-person

Most people: Levels 1-3. Security-conscious: Level 4. Enterprise: Level 5.

🔴 LIVE DEMO

Setting Up a Dedicated Agent

🏗️ The Full Picture

From god-mode agent to **secure architecture**:

🔐
Know the risks
Injection & exfiltration

🛡️
Least privilege
Minimum access per agent

⚡
Subagents
Background parallel tasks

🧵
Threads & Groups
Platform-level isolation

🤝
Multiple agents
Real security isolation

💰
Smart costs
Right model for the job

💰 Cost Management

Running AI agents costs real money

💰 Three Ways to Pay

📱 Claude Subscription

Simplest option

- Pro: **$20/mo** (light use)
- Max: **$200/mo** (recommended)

Max gives enough headroom for daily use with Opus

🧠 Cheaper Models

For simple tasks

- **Kimi 2.5** — cheap, fast
- Good for cron jobs, drafts
- Use **/models** to switch

Not as advanced, but fine for routine work

🎟️ Startup Credits

Free money you might already have

- Anthropic, OpenAI, Google
- AWS Bedrock credits
- Ask your team!

Some teams have $1000s sitting unused

💰 Smart Model Routing

Use **/models** in Telegram — expensive for hard tasks, cheap for routine

TASK	MODEL	WHY
News briefing, inbox scan, formatting	**Kimi 2.5 / Haiku**	Cheap, fast, good enough
Email drafts, research, scheduling	**Sonnet / GPT-4o**	Balanced
Complex analysis, security-sensitive	**Opus / Claude Max**	Best judgment, worth the cost

> Don't use Opus to check the weather. Don't use Kimi for security decisions. Match the model to the task.

📝 Before Demo Day (Monday)

- 🔐 Run the **prompt injection test** on your agent
- 🔍 Do an **access audit** — know what your agent can see
- ⚡ Try **subagents** for background tasks
- 🧵 Use **threads** for parallel conversations
- 🤝 Plan (or create) a **second dedicated agent**
- 🎯 Prepare your **demo** — show what your agent can do!

> Workshop 1: foundation. Workshop 2: useful. Workshop 3: secure & scalable. Monday: show the world.

❓ Questions?

Q&A

WhatsApp group for follow-ups

Book a meeting to unblock — we're here to help